

VOLUME 6 OF 6 — CAPSTONE

Operating Model, Maturity Model & 24-Month Roadmap

Enterprise Agent Operating Model, Maturity Levels, Security Review Checklists, Principal Architect Interview Guide, and the Learning Path

Document Code: EASA-06

Version: 1.0

Date: June 2026

Scope: Domain 22 & Program Deliverables

Enterprise Agentic AI Security Architect (2026–2030) Master Research Program

Table of Contents

Executive Summary

The first five volumes of this program answered "what does a secure, governed agentic AI ecosystem look like." This volume answers the harder organizational question: who builds it, who runs it, how is success measured, and in what order should an enterprise actually do this work given finite budget and finite people. It closes the program with the operating model (Domain 22), a five-level maturity model the enterprise can use to self-assess and to set a realistic multi-year target, a consolidated set of review checklists, an interview guide for hiring into this role, and a curated learning path — because the most sophisticated reference architecture in the world is only as good as the organization's ability to staff, govern, and continuously operate it.

Domain 22 — Enterprise Agent Operating Model

No single team owns agentic AI security end to end, and attempting to build one monolithic team is a common and costly early mistake. The operating model this program specifies distributes accountability across five functions, deliberately mirroring how mature organizations already split traditional cybersecurity, cloud platform engineering, and data governance — because reporting agentic AI risk through entirely new, parallel structures tends to isolate it from the rest of the enterprise's risk management muscle rather than integrating with it.

22.1 The Five Functions

Function	Primary Mandate	Reports Into / Coordinates With
AI Governance Board	Sets policy, approves autonomy-level thresholds, owns the framework crosswalk (Volume 3, Domain 3.6), and is the final escalation point for risk acceptance decisions on individual agents	Chaired by the AI CISO; includes Legal, Compliance, Enterprise Architecture, and business-unit risk owners
AI Security Office	Owns the architecture and policy specified in Volumes 1-3: identity substrate, MCP/A2A gateways, governance fabric, supply-chain controls	Reports to the AI CISO; works day-to-day with Platform Engineering on implementation
Agent Operations Team	Day-to-day agent lifecycle management: registration, provisioning, autonomy-level changes, retirement — operationalizing the Agent Registry (Volume 3, Domain 14)	Reports to the AI Platform Architect; the team accountable for the Agent Registry's accuracy
Platform Engineering Team	Builds and operates the runtime, gateways, and mesh infrastructure (Volume 1, Domains 7 and 20; Volume 2 MCP/A2A gateways)	Reports to the AI Platform Architect; the engineering counterpart to the AI Security Office's policy
AI SOC	Continuous monitoring, detection, and incident response (Volume 4, Domain 10), including operating the kill-switch framework	Reports to the AI CISO, typically integrated into or co-located with the existing enterprise SOC
Red Team	Adversarial testing (Volume 4, Domain 12), feeding purple-team findings back into the AI SOC's detection logic	Reports to the AI CISO, organizationally independent from the AI Security Office to preserve adversarial objectivity

22.2 RACI — Core Program Activities

Activity	AI Gov. Board	AI Security Office	Agent Ops	Platform Eng.	AI SOC	Red Team
Approve new agent autonomy level $\geq$ L3	A	C	R	I	I	I
Define identity & MCP/A2A policy	C	A/R	I	C	I	I

Activity	AI Gov. Board	AI Security Office	Agent Ops	Platform Eng.	AI SOC	Red Team
Build & operate gateways and mesh	I	C	I	A/R	C	I
Maintain Agent Registry	I	C	A/R	I	C	I
Monitor & triage security incidents	I	C	C	C	A/R	I
Execute kill switch	I	C	C	C	A/R	I
Conduct red/purple team exercises	I	C	I	C	C	A/R
Regulatory filing / incident reporting	A	C	I	I	R	I
Quarterly risk reporting to board	A/R	C	I	I	C	I

R = Responsible, A = Accountable, C = Consulted, I = Informed.

22.3 KPIs

KPI	Target Direction	Primary Source
% of active agents with complete Agent Registry entries	↑ toward 100%	Agent Registry audit (Volume 3, Domain 14)
% of agents with standing (non-ephemeral) credentials	↓ toward 0%	Identity substrate audit (Volume 2, Domain 2)
Mean time to detect (MTTD) an ASI-mapped incident	↓	AI SOC (Volume 4, Domain 10)
Mean time to contain (MTTC) via kill switch	↓	AI SOC incident logs
Goal conformance rate (fleet average)	↑	Agent Reliability Engineering (Volume 4, Domain 19)
% of red-team findings with a corresponding purple-team detection pattern shipped	↑ toward 100%	Purple Team tracking (Volume 4, Domain 12.2)
% of MCP servers / A2A peers passing gateway validation on first registration attempt	Track trend, not a target direction in isolation	MCP/A2A gateway logs (Volume 2)
Framework crosswalk coverage (regulations with current, evidenced control mapping)	↑ toward 100%	AI Governance Board (Volume 3, Domain 11)

Enterprise Agent Maturity Model (Levels 1–5)

Use this model for honest self-assessment, not for marketing the program internally. Most enterprises deploying agents in production today, including ones with significant AI investment, sit at Level 1 or the early part of Level 2 — current CSA and NIST research on the state of agent identity (Volume 2, Domain 2) is consistent on this point: authentication is largely solved with static credentials, while authorization, lifecycle management, and governance are not.

Level	Designation	Characteristic State	Identity Pattern	Governance Pattern
1	Ad Hoc	Agents deployed by individual teams with no central inventory; security is whatever the deploying team happened to implement	Static API keys, shared service accounts	No central registry; no formal autonomy-level concept
2	Aware	A central team has visibility into most agents and has begun applying baseline controls, but enforcement is inconsistent across business units	Mix of static credentials and early workload-identity pilots	Agent Registry exists but is incomplete; manual, periodic review
3	Managed	Identity substrate (SPIFFE or equivalent) and MCP/A2A gateways are deployed organization-wide; the Agent Registry is the authoritative source of truth; autonomy levels are assigned and enforced	Ephemeral, workload-identity-issued credentials as the default	Framework crosswalk operating; AI Governance Board meets on a regular cadence
4	Measured	Agent Reliability Engineering SLIs/SLOs are operating; AI SOC correlates across all seven monitored surfaces (Volume 4, Domain 10.2); kill-switch and FinOps circuit breakers are unified and tested	Trust-score-informed dynamic authorization (Volume 3, Domain 13) layered on identity	Purple-team loop closed; KPIs reported quarterly to the board with trend data, not point-in-time snapshots
5	Optimizing	Post-quantum-ready identity and payment infrastructure; agent trust extends to verified external counterparties via decentralized identity / verifiable credentials; the program contributes back to industry standards bodies	Hybrid classical/PQC credentials; verifiable-credential-based external trust	Governance model anticipates regulatory change rather than reacting to it; the enterprise is a reference case other organizations benchmark against

Level	Designation	Characteristic State	Identity Pattern	Governance Pattern
		rather than only consuming them		

Security Review Checklists

These are intentionally condensed to the highest-leverage items from each volume — gate checklists for the two moments that matter most: approving a new agent for production, and approving a new MCP server or A2A counterparty for connection. Each should be backed by the full control detail in the referenced volume; treat this as the pass/fail gate, not the complete control set.

New Agent Production Readiness Checklist

- ☐ **Identity** — Agent has a SPIFFE SVID or equivalent workload identity; no static, long-lived credentials present (Volume 2, Domain 2).
- ☐ **Registry** — Agent Registry entry complete: purpose, sponsor, autonomy level, scoped tools (Volume 3, Domain 14).
- ☐ **Least Agency** — Autonomy level matches a documented risk classification; no standing access beyond what the level requires (Volume 1, Domain 1; Volume 3, Domain 14).
- ☐ **Threat model** — MAESTRO-based threat model completed and reviewed for this agent's architecture pattern (Volume 1, Domain 1.5).
- ☐ **Runtime isolation** — Sandboxing tier assigned matches the agent's trust-boundary exposure (Volume 1, Domain 7.1).
- ☐ **Tool scope** — Every tool/MCP connection passes gateway validation; no direct, unmediated credentials held by the agent (Volume 2, Domain 5.4).
- ☐ **Memory governance** — Memory writes are classified and provenance-tagged at write time; retention policy assigned (Volume 4, Domain 9.3).
- ☐ **Human oversight** — Approval gates defined for any irreversible or high-consequence action regardless of trust score (Volume 3, Domain 13.3).
- ☐ **Observability** — Agent is instrumented to the OpenTelemetry/OpenLLMetry standard and visible to the AI SOC (Volume 4, Domain 10).
- ☐ **Reliability** — SLIs/SLOs defined with an error-budget-triggered autonomy downgrade path (Volume 4, Domain 19.2).
- ☐ **FinOps** — Budget envelope and spend-velocity anomaly detection configured (Volume 5, Domain 15.2).
- ☐ **Kill switch** — Tested, identity-layer kill-switch capability confirmed before go-live (Volume 3, Domain 14.3).
- ☐ **Compliance crosswalk** — Agent's risk tier mapped against applicable regulation (EU AI Act Annex III high-risk status, DORA, PCI DSS, GDPR memory implications) (Volume 3, Domain 3.6).

New MCP Server / A2A Counterparty Connection Checklist

- ☐ **Provenance** — Server/agent publisher identity verified; for A2A, Agent Card signature cryptographically verified against the claimed domain (Volume 2, Domain 6.1).
- ☐ **Scanning** — Tool definitions and descriptions scanned for hidden-instruction / poisoning patterns prior to registration (Volume 2, Domain 5.3).

- ☐ **Schema validation** — Discovery-time and invocation-time schema validation both configured at the gateway, not discovery-time only (Volume 2, Domain 5.4).
- ☐ **Transport** — mTLS enforced; unauthenticated transport rejected by default policy (Volume 2, Domains 5.4 and 6.3).
- ☐ **Tool signing** — Tool signatures verified where supported; re-verification triggers configured to catch "rug pull" post-install modification (Volume 2, Domain 5.2).
- ☐ **Tenant isolation** — Multi-tenant servers confirmed to enforce session and credential isolation between tenants (Volume 2, Domain 5.2).
- ☐ **Trust broker** — External A2A counterparty has an assigned trust score and recorded trust relationship before any production task delegation (Volume 3, Domain 13.2).
- ☐ **Spend caps** — Per-task spend caps configured for any counterparty connection capable of initiating cost or financial transactions (Volume 5, Domains 15 and 16).
- ☐ **Audit logging** — Tamper-evident logging confirmed operational for the new connection before production traffic flows (Volume 2, Domains 5.4 and 6.3).
- ☐ **Supply chain** — Component recorded in the AI BOM with applicable provenance documentation (Model Card / Agent Card) (Volume 3, Domain 17).

Principal Architect Interview Guide

These questions are designed to distinguish candidates who have absorbed current best practice from those who can reason architecturally about a fast-moving, still-converging field — the latter matters more, because much of the specific tooling and even some of the standards referenced in this program will have moved by the time a hire is six months into the role.

Architecture & Threat Modeling

1. Walk me through how you would threat-model a multi-agent system using MAESTRO, and specifically describe a cross-layer threat that a single-layer review would miss.
2. An agent has a clean identity, a clean trust score, and has behaved correctly for six months. Describe a realistic attack path that still succeeds against this agent, and what control would have caught it.
3. When would you choose Firecracker over gVisor over WASM for sandboxing an agent's tool execution, and what's the wrong reason to choose one over another?

Identity & Trust

1. Explain the difference between authenticating a workload and authorizing an action, and describe a real architecture where conflating the two created a vulnerability.
2. How would you design compound identity for an agent acting on behalf of a suspended user account, and what should happen?
3. What is the structural limitation of SPIFFE for agent security, and what has to be layered on top of it?

MCP / A2A

1. Describe tool poisoning in your own words, and explain why discovery-time schema validation alone is insufficient to prevent it.
2. A vendor pitches an MCP server with no gateway in front of it, claiming their server is "secure by design." What is your response, and what would you require before connecting it?
3. What changed in A2A v1.0 that materially improved enterprise trust in the protocol, and what gap still remains even with that change?

Governance & Judgment

1. A business unit wants to deploy an L4 (full autonomy) agent against a use case you believe should be L2. Walk me through how you'd handle that conversation.
2. How do you decide which emerging framework (a new OWASP sub-project, a new IETF draft, a new vendor "standard") is worth building architecture around versus tracking and waiting?
3. Describe an incident where a reliability problem and a security problem were actually the same underlying issue, and how your operating model would surface that connection rather than splitting it across two teams.

24-Month Learning & Implementation Roadmap

This roadmap is sequenced for an enterprise architect or security architect building both their own expertise and the organization's capability simultaneously — the realistic situation most readers of this program are in, rather than joining an already-mature function.

Months 1–3: Foundation

- Complete Volume 1 (Foundations & Reference Architecture) and produce the Agent Security Architecture Repository for at least one business unit as a pilot.
- Stand up an Agent Registry, even a minimal one, and run a discovery exercise to find every agent currently running in the enterprise — the inventory gap is almost always larger than expected.
- Begin or accelerate ISO 42001 gap analysis (Volume 3, Domain 3.6), particularly if any system may fall under EU AI Act Annex III high-risk classification given the August 2026 enforcement milestone.

Months 4–9: Identity & Protocol Security

- Deploy or extend a SPIFFE/SPIRE trust domain to cover agent workloads (Volume 2, Domain 2).
- Stand up an MCP gateway with the five-stage validation pipeline (Volume 2, Domain 5.4) for at least the highest-risk tool integrations.
- Establish the AI Governance Board and produce the first version of the framework crosswalk (Volume 3, Domains 3.6 and 11).
- Define the five-level autonomy taxonomy and retroactively classify every registered agent (Volume 3, Domain 14.2).

Months 10–15: Operations & Resilience

- Stand up the AI SOC's cross-surface correlation capability, even in an early form, on top of an existing observability platform (Volume 4, Domain 10).
- Run the first red team exercise mapped explicitly against the OWASP ASI Top 10, and close the loop with the first purple-team detection patterns (Volume 4, Domain 12).
- Define and begin tracking the first Agent Reliability Engineering SLIs/SLOs (Volume 4, Domain 19).
- Build and test the unified kill-switch / circuit-breaker mechanism spanning both security and FinOps triggers (Volume 5, Domain 15.2).

Months 16–24: Scale & Future-Proofing

- Extend the A2A gateway and trust-broker infrastructure to cover external counterparties, if the enterprise's use cases require cross-organization agent collaboration (Volume 2, Domain 6.3; Volume 3, Domain 13.2).
- Pilot delegated agent spending under AP2 or an equivalent payment-mandate protocol for a bounded, low-risk use case, with full FinOps and cognitive-security controls in place first (Volume 5, Domain 16).

- Begin architecting crypto-agility into every new identity, MCP, A2A, and payment-mandate component (Volume 5, Domain 21) — not a full PQC migration, but ensuring nothing built in this window becomes a forklift-upgrade liability later.
- Conduct a full maturity-model self-assessment against the five-level model in this volume and set the explicit, board-approved target maturity level for the following 24 months.

Certifications, Standards, and Communities to Track

Certifications

Certification	Focus	Best Fit
CAISP (Certified AI Security Professional, Practical DevSecOps)	Full-stack AI security: prompt injection, NIST AI RMF alignment, AI red teaming, OWASP LLM Top 10 and agentic attack patterns	Security professionals and architects wanting balanced offense/defense/governance coverage; widely cited as the broadest single AI security credential as of 2026
COASP (Certified Offensive AI Security Professional, EC-Council)	Pure offensive specialization: AI attack-surface mapping, adversarial ML, agentic exploitation, AI incident response	Experienced red teamers adding AI-specific offensive skills
OSAI (OffSec)	Offensive AI techniques with an extended, exam-style endurance assessment	Practitioners who already hold OffSec credentials and want AI-specific depth
AIGP (AI Governance Professional, IAPP)	Policy, compliance, and risk management rather than technical security	GRC professionals, privacy officers, and AI Governance Board members rather than hands-on architects

AI security roles are commanding meaningfully elevated compensation as of 2026, reported in the roughly \$150,000–\$290,000 range depending on seniority and specialization, reflecting both the acute skills shortage and the speed at which the field is professionalizing.

Standards Bodies and Initiatives to Track Directly

- OWASP GenAI Security Project — genai.owasp.org — primary source for the ASI Top 10, the emerging MCP Top 10, the Agentic Skills Top 10, and the AIBOM Generator initiative.
- Cloud Security Alliance — the MAESTRO framework and ongoing CSA research notes on agent identity and NHI.
- NIST AI Agent Standards Initiative and NCCoE agent identity concept paper — track for the eventual interoperability profile (expected Q4 2026 draft).
- IETF WIMSE working group — workload-identity-to-workload-identity authentication standards underpinning the AIMS draft architecture (Volume 2, Domain 2.3).
- Linux Foundation Agent2Agent Protocol Project — the neutral governance body for A2A since Google's June 2025 donation.
- FIDO Alliance Payments Technical Working Group — now governing AP2's standards-track evolution, including its post-quantum profile.
- MITRE ATLAS — atlas.mitre.org — continuously updated adversary-tactics knowledge base for AI-specific techniques.

Open-Source Tooling and Repositories Worth Evaluating

- SPIFFE/SPIRE (CNCF) — the reference workload-identity implementation underpinning Volume 2's identity architecture.
- OWASP MCP-Scan and equivalent scanners (Cisco mcp-scanner, Snyk agent-scan) — pre-deployment MCP tool scanning.
- OpenLLMetry / Traceloop — vendor-neutral OpenTelemetry instrumentation for agent and LLM traces.
- MAESTRO threat-modeling tooling (Cloud Security Alliance GitHub) — AI-assisted, layer-by-layer threat identification aligned to the seven-layer reference architecture.
- Promptfoo and DeepTeam — open-source red-teaming frameworks with test suites mapped directly to the OWASP ASI Top 10.
- Open Policy Agent (OPA) and Cedar — the two leading policy-engine choices for the centralized authorization layer specified throughout this program.

Closing Note: How to Use This Program

Six volumes, twenty-two domains, and a stack of checklists are only useful if they change what gets built and funded. The single most consequential decision a reader of this program can make is the one flagged at the close of Volume 2: fund the identity substrate first. Almost everything else in this program — MCP gateway policy, A2A trust brokering, agent registry enforcement, FinOps circuit breakers, even post-quantum migration — becomes simpler, cheaper, and more defensible once every agent, tool, and peer in the ecosystem carries a verifiable, ephemeral, centrally governed identity. Build that first, build the governance fabric around it second, and treat the remaining domains in this program as the detailed specification for what to do once that foundation is in place — not as a checklist to attack in parallel from a standing start.

This program reflects the state of a genuinely fast-moving field as of June 2026. Treat the architectural patterns — identity-first design, centralized gateways, layered threat modeling, autonomy earned rather than granted by default — as durable. Treat the specific vendor names, protocol version numbers, and standards-body timelines as a snapshot to be re-verified against current sources before any major investment decision.